

Course code: IOS3100

Course name: IoT/OT security

Assessment type: Individual written home examination

Date of examination/hand out- and hand in date: 03.12.2024 10:00 – 10.12.2024 10:00

Permitted exam materials and equipment: All support materials are allowed

File format: PDF

Number of pages: The limit is 15 pages max. The references, table of contents, title page, abstract comes in addition to that.

Plagiarism detection: All exam papers, including bachelor's and master's theses will be checked for plagiarism. You can read more about this in the guidelines on citing sources (referencing), plagiarism, and formal requirements for submitting assignments.

Grading scale: The Norwegian grading system uses the graded scale A - F, where A is the best grade, E is the lowest pass grade, and F is fail

General information:

- Start uploading your exam paper/file ahead of time, as it may take a long time to upload
- Exam papers that are not handed in on Wiseflow by the specified time of the submission date will not be proceeded to assessment
- Before submitting, remember to check that all files can be opened and that every file is included. It may be a good idea to check the saved files on several machines before submitting in Wiseflow.
- Incorrect file format or lacking documents may result in the submission not being passed or assessed.
- The total file size of the entire exam paper/file must not exceed 5GB in zip format or 5MB in PDF format

Learning Outcome as per course description

Knowledge. The student...

- can define and explain security issues in IoT systems
- can explain and problematize how the spread of IoT systems in both our daily lives and critical infrastructure will affect security from a societal perspective
- can define and explain selected architectures and protocols in use in IoT devices
- can define and explain security issues in OT systems
- can explain patch problems related to running OT systems, understand what risks may be associated with this from an operational perspective and from a security perspective
- can define and explain selected architectures in use in OT environments
- can explain the challenges and benefits of performing penetration tests in an OT environment

Skills. The student...

- can use tools for static security analysis and code auditing
- can understand the principles behind reverse engineering of hardware and software in an embedded / IoT device, and what effects this has on security
- can carry out a vulnerability analysis / penetration test of IoT devices
- can use tools to carry out vulnerability analyzes and risk analyzes of an OT environment / system
- can analyze protocols used in IoT systems, and use this to uncover security vulnerabilities

General competence. The student...

- can understand and problematize the advantages and disadvantages associated with the emergence of IoT devices and OT systems that are connected to the Internet
- can carry out a security analysis of an IoT product, and understand what threats this product can introduce if it is used in the contexts; private, company and public
- can carry out safety management and risk management of OT projects

Exam Task

Task A – theoretical task (20% of the grade)

A.1: Select any two guest lectures we had in this course and reflect on the content of the guest lectures and essential aspects of IoT security that each particular guest lecturer highlighted. Present how this knowledge helped you to better understand concepts from the course. **(10%)**

A.2: Explain your understanding of how the devices shown in Lecture 6 (slide 68) and Lecture 7 (slide 64) can be used for the security assessment of generic IoT smart home applications. **(10%)**

Task B – use cases (40% of the grade)

B.1: In Lecture 9 (slide 96), you are given a diagram of a generic Bluetooth Low Energy and Cloud application integration implementation. Perform security analysis using three steps of the STRIDE framework (1. *Identify the architecture*, 2. *Break it into components*, 3. *Identify threats to each component*) and support your answers with a diagram of possible trust boundaries. The model and relevant approach can be found in Chapters 2/3 of the main textbook *“Practical IoT Hacking: The Definitive Guide to Attacking the Internet of Things”* by Fotios Chantzis et al. **(20%)**

B.2: Select two possible attack scenarios to answer task B.1 above and analyze the attacks using a numeric DREAD risk-based framework (scale 0-10), as shown in Lecture 2 (slides 59-60). The model and relevant approach can be found in Chapters 2/3 of the main textbook *“Practical IoT Hacking: The Definitive Guide to Attacking the Internet of Things”* by Fotios Chantzis et al. **(20%)**

Task C – practical task (40% of the grade)

C.1: Design and implement a simple MQTT-based IoT application that will include three components:

- a plant/flowers watering and monitoring station
- a server-based cloud solution that aggregates all information
- a user-based mobile client that demonstrates historical conditions of the soil humidity

This can be an emulated IoT ecosystem (without physical sensors or water pumps) using virtual machine(s) **OR** at docker instance(s). Draw a diagram of the designed system. The system should include at least a database, IoT application protocols, a central broker, and a client application. You can use either of the technologies: Mosquitto, MQTT Explorer, MySQL, OpenStack, Python, PHP or similar with default configurations. Demonstrate vulnerabilities and possible weaknesses of the system, and perform any types of attacks that you have learnt in the program reflecting the OWASP Top 10 IoT Security Risks (https://wiki.owasp.org/index.php/OWASP_Internet_of_Things_Project). Suggest possible protection and security measures. **(30%)**

C.2: In this course, you have learned about the importance of security assessment in IoT applications. Pick any open-source projects implemented for any Arduino / ESP32 boards (from <https://github.com/>, <https://projecthub.arduino.cc/>, etc). The project must include any type of web server implementation that is accessible through the network. Download the main .ino file from a project and present a simple diagram of functionality implemented in *setup()* and *loop()* procedures. Analyze the selected IoT project and write a list of corresponding *Devices Properties*, *Threats* and *Mitigations* according to MITRE EMB3D™ Threat Model framework (<https://emb3d.mitre.org/>). All three categories need to include corresponding identifiers and descriptions from EMB3D for each of the assessment steps (<https://emb3d.mitre.org/getting-started/>). **(10%)**